Internal Audit Report

Botium Toys – Cybersecurity Program

1. Introduction

Scope: The scope of this audit encompasses the entire security program at Botium Toys. This includes all assets, business applications, and compliance with PCI DSS, GDPR, and SOC standards.

Goals: Assess the adequacy of existing assets, security controls, and compliance practices; identify security gaps; and provide recommendations to strengthen Botium Toys' security posture.

Methodology: The audit was conducted using the risk assessment report, controls and compliance checklist, control categories, and compliance frameworks (PCI DSS, GDPR, SOC).

2. Assets Overview

The IT Department manages: on-premises office and retail equipment, employee end-user devices, storefront/warehouse products, accounting and ecommerce systems, internal network and internet access, data retention and storage systems, and legacy systems requiring manual monitoring.

3. Risk Assessment Summary

Risk Score: 8/10 (High).
Primary Risks: Inadequate asset management, lack of encryption, incomplete compliance, excessive employee access, no IDS, no disaster recovery/backup.
Impact: Medium (uncertain asset risk), High (regulatory fines, breaches, reputational damage).

4. Controls Assessment

Control	In Place	Explanation
Least Privilege	No	All employees have access to data
Disaster Recovery Plans	No	No recovery framework
Password Policies	No	Weak and outdated
Separation of Duties	No	CEO manages multiple sensitive functions
Firewall	Yes	Configured with rules
Intrusion Detection System	No	No IDS deployed
Backups	No	No backup solution
Antivirus Software	Yes	Installed and monitored
Legacy Systems Monitoring	Partial	Monitored but no formal schedule

Control	In Place	Explanation
Encryption	No	Sensitive data not encrypted
Password Management	No	No centralized system
Locks	Yes	Physical locks in place
CCTV	Yes	Operational
Fire Detection	Yes	Functional alarms and sprinklers

5. Compliance Assessment

• PCI DSS: Non-compliant (no encryption, weak password policies, unrestricted access).
• GDPR: Partially compliant (72-hour notification plan exists; no encryption or classification).
• SOC 1/2: Partially compliant (data integrity in place; missing access controls and encryption).

6. Findings & Recommendations

Key Findings: Lack of encryption, excessive access privileges, weak passwords, missing IDS, no backups, and inadequate legacy monitoring.

Recommendations:
- Implement least privilege and separation of duties.
- Deploy encryption for credit card and PII data.
- Establish disaster recovery and backup plans.
- Adopt stronger password policies and a password management system.
- Deploy IDS/IPS for intrusion detection and prevention.
- Formalize legacy system monitoring.
- Classify and inventory assets.

7. Conclusion

Botium Toys demonstrates basic protections (firewall, antivirus, CCTV, locks, fire detection). However, critical gaps exist in encryption, access management, compliance, and disaster recovery. Immediate action is required to improve security posture and protect sensitive data.